

A project report on

**AISPM
AI SECURITY POSTURE MANAGEMENT**

Submitted in partial fulfillment for the award of the degree of

**Bachelor of Technology in Computer
Science and Engineering with
Specialization in Cyber Physical Systems**

By

AARTHI R (22BPS1042)



**SCHOOL OF COMPUTER SCIENCE
AND ENGINEERING (SCOPE)**

May , 2026

AISPM
AI SECURITY POSTURE MANAGEMENT

Submitted in partial fulfillment for the award of the degree of

**Bachelor of Technology in Computer
Science and Engineering with
Specialization in Cyber Physical Systems**

By

AARTHI R (22BPS1042)



**SCHOOL OF COMPUTER SCIENCE
AND ENGINEERING (SCOPE)**

May , 2026

DECLARATION

I here by declare that the thesis entitled “AISPM – AI Security Posture Management” submitted by me, for the award of Bachelor of Technology in Computer Science Engineering with specialization in Cyber Physical Systems is a record of bonafide work carried out by me.

I further declare that the work reported in this thesis has not been submitted and will not be submitted, either in part or in full, for the award of any other degree or diploma in this institute or any other institute or university.

Place: Bangalore

Date: 28-05-2026



Signature of the Candidate

Aarthi R

From: Sachin Taklekar
Sent: 28 May 2026 13:06
To: Aarthi R; Naman Tiwari; Eakshitha Cheppali
Subject: FW: EY India - VIT University || Interns' Request for Completion Certificate

Importance: High

Dear @Aarthi, @Naman and @Eakshitha,
Greetings..!!

Please find the below acknowledgement from the college placement cell.

Thanks & Regards,
Sachin J Taklekar
Engineering University Recruiting - EY India
<https://www.linkedin.com/in/sachinjtaklekar/>

From: VIT Placement <placement@vit.ac.in>
Sent: Thursday, May 28, 2026 1:22 PM
To: Sachin Taklekar <Sachin.Taklekar@in.ey.com>
Cc: Gayatri Seeji <Gayatri.Seeji@in.ey.com>; Akshita Kaul <Akshita.Kaul@in.ey.com>
Subject: Re: EY India - VIT University || Interns' Request for Completion Certificate

Dear sir,

Acknowledged

Warm regards.
Dr.V.Samuel Rajkumar, PhD
Director(Career Development Centre)
VIT, Vellore
[Vellore Institute of Technology \(VIT\), India -](#)

- [Engineering and Technology: 119th in the World and 6th in India \(QS World University Rankings by Subject 2026\)](#)
- [Computer Science, Information Systems, Electrical, and Electronics subject areas are within the Top 100 in the world. Data Science and AI, Mathematics, Material Science, Mechanical, and Manufacturing subjects are within the top 200 in the world \(QS World University Rankings by Subject 2026\)](#)
- [Within the top 2 in India and top 600 in the world \(Shanghai ARWU ranking 2025\)](#)
- [NAAC Accreditation with A++ grade \(3.66 out of 4\)](#)
- [Within the top 20 in University, Research, and Engineering categories in India \(NIRF Ranking, Govt. of India 2025\)](#)
- [352nd in the world and 7th in India \(QS World University Rankings: Sustainability 2026\)](#)

On Thu, May 28, 2026 at 12:54 PM Sachin Taklekar <Sachin.Taklekar@in.ey.com> wrote:

Dear @Dr. Ganesh and Team,

Greetings..!!

We are receiving several requests from interns who joined us from your institution, VIT University (Vellore, Chennai, Amravati and Bhopal Campuses), regarding the issuance of their internship completion certificates.

Please note that these certificates are system-generated and will only be issued upon the successful completion of their internship, which is scheduled end on 31st July 2026 from the initial end date of 30th June 2026.

Therefore, we are unable to provide the certificates at this time.

To ensure there is no gap in documentation from our side, we are sharing this communication for your internal official records.

Kindly consider this email as an interim document in place of the internship completion certificates until the formal certificates are issued.

Thank you for your understanding and cooperation.

Please feel free to reach us in case of any queries or clarifications.

Sachin J Taklekar

Asst. Manager - University Recruiting & Relations

Contact Number: 8792493529

EY India (Ernst & Young Services Pvt. Ltd.)

<https://www.linkedin.com/in/sachinjtaklekar/>

Find us on: www.ey.com | [Facebook](#) | [LinkedIn](#) | [Twitter](#) | [YouTube](#)



ABSTRACT

The rapid proliferation of Artificial Intelligence and Machine Learning systems across enterprise environments has introduced a new category of security challenges that traditional cybersecurity tools are ill-equipped to address. Organizations deploying AI systems face unique threats including adversarial attacks, model poisoning, data leakage through inference, supply chain compromises in model artifacts, and regulatory non-compliance with emerging AI-specific legislation such as the EU AI Act, NIST AI Risk Management Framework, and ISO 42001.

This project presents the design and implementation of an AI Security Posture Management (AISPM) Platform an enterprise-grade solution developed during an internship at Ernst & Young (EY) that provides comprehensive visibility, risk assessment, compliance monitoring, and automated governance for an organization's entire AI ecosystem. The platform encompasses 12 core modules addressing asset discovery, vulnerability management, LLM governance, responsible AI, data risk, vendor risk management, regulatory intelligence, and executive reporting.

The system architecture employs a modular monolith pattern built on Fast API (Python 3.11) for the backend with 70+ specialized microservices, React 18 with TypeScript for the frontend comprising 28+ interactive pages, and a polyglot persistence layer utilizing PostgreSQL, Redis, Neo4j, and MongoDB. The platform integrates 14 industry-leading open-source tools including IBM's Adversarial Robustness Toolbox for attack simulation, Microsoft's Presidio for PII detection, Flower for federated learning, and OpenDP for differential privacy guarantees.

The platform achieves production-ready status with 26,000+ lines of code, comprehensive JWT-based authentication with role-based access control supporting 7 user roles and 20+ granular permissions, Redis-backed distributed rate limiting, and full compliance coverage across EU AI Act, NIST AI RMF, ISO 42001, OWASP Top 10 for LLM, and MITRE ATLAS frameworks. Performance benchmarks demonstrate sub-2ms authentication overhead and p95 API response times under 200ms.

Keywords: AI Security, AISPM, Machine Learning Security, LLM Safety, AI Governance, Risk Management, Compliance Automation, Fast API, React, Enterprise Security Platform.

ACKNOWLEDGEMENT

It is with gratitude that I would like to extend my thanks to the visionary leader Dr. G. Viswanathan our Honorable Chancellor, Mr. Sankar Viswanathan, Dr. Sekar Viswanathan, Dr. G V Selvam Vice Presidents, Dr. Sandhya Pentareddy, Executive Director, Ms. Kadhambari S. Viswanathan, Assistant Vice-President, Dr. V. S. Kanchana Bhaaskaran Vice-Chancellor, Dr. T. Thyagarajan Pro-Vice Chancellor, VIT Chennai and Dr. P. K. Manoharan, Additional Registrar for providing an exceptional working environment and inspiring all of us during the tenure of the course.

Special mention to Dr. Viswanathan V, Dean, Dr. Nithyanandam P, Dr. Suganya G, Dr. Sweetlin Hemalatha C, Associate Deans, School of Computer Science and Engineering, Vellore Institute of Technology, Chennai for spending their valuable time and efforts in sharing their knowledge and for helping us in every aspect.

In jubilant state, I express ingeniously my whole-hearted thanks to Dr. S. Renuka Devi, Head of the Department, B.Tech. Computer Science and Engineering in Cyber Physical Systems and the Project Coordinators for their valuable support and encouragement to take up and complete the thesis.

It is indeed a pleasure to thank my friends who persuaded and encouraged me to take up and complete this task. At last but not least, I express my gratitude and appreciation to all those who have helped me directly or indirectly toward the successful completion of this project.

Place: Bangalore

Date:28-05-2026

Aarthi R

CONTENTS

CONTENTS	iii
LIST OF TABLES	vii
LIST OF ACRONYMS	viii
Chapter 1 Introduction	1
1.1 BACKGROUND AND MOTIVATION	1
1.2 PROBLEM STATEMENT	3
1.3 OBJECTIVES OF THE PROJECT	4
1.4 SCOPE OF THE PROJECT	5
Chapter 2 Literature Review	7
2.1 AI SECURITY LANDSCAPE	7
2.2 EXISTING AI SECURITY FRAMEWORKS	8
2.3 AI-SPECIFIC THREAT TAXONOMY	10
2.4 REGULATORY LANDSCAPE FOR AI SYSTEMS	13
2.5 EXISTING AISPM SOLUTIONS	14
2.6 OPEN-SOURCE TOOLS FOR AI SECURITY	15
2.7 RESEARCH GAPS AND MOTIVATION	17
Chapter 3 System Design and Architecture	19
3.1 SYSTEM REQUIREMENTS	19
3.1.1 FUNCTIONAL REQUIREMENTS	19
3.1.2 NON-FUNCTIONAL REQUIREMENTS	20
3.2 HIGH-LEVEL ARCHITECTURE	20
3.3 BACKEND ARCHITECTURE	21
3.3.1 APPLICATION STRUCTURE	21
3.3.2 MIDDLEWARE PIPELINE	21
3.4 FRONTEND ARCHITECTURE	22
3.4.1 COMPONENT ARCHITECTURE	22
3.4.2 STATE MANAGEMENT STRATEGY	22
3.5 DATABASE DESIGN	23
3.5.1 POSTGRESQL (PRIMARY TRANSACTIONAL DATABASE)	23
3.5.2 REDIS (CACHE AND RATE LIMITING)	23
3.5.3 NEO4J (GRAPH DATABASE)	23

3.5.4 MONGODB (DOCUMENT STORE)	23
3.6 SECURITY ARCHITECTURE	24
3.6.1 AUTHENTICATION FLOW	24
3.6.2 AUTHORIZATION MODEL.....	24
3.6.3 DATA PROTECTION.....	24
3.7 DEPLOYMENT ARCHITECTURE	24
3.7.1 DEVELOPMENT ENVIRONMENT	24
3.7.2 PRODUCTION ENVIRONMENT	25
3.7.3 CI/CD PIPELINE.....	25
Chapter 4 Implementation	26
4.1 DEVELOPMENT ENVIRONMENT SETUP	26
4.2 BACKEND IMPLEMENTATION	26
4.2.1 FASTAPI APPLICATION CONFIGURATION	26
4.2.2 RATE LIMITING IMPLEMENTATION	26
4.2.3 ASSET DISCOVERY ENGINE IMPLEMENTATION	26
4.2.4 RISK ASSESSMENT IMPLEMENTATION	27
4.2.5 COMPLIANCE ENGINE IMPLEMENTATION	27
4.3 FRONTEND IMPLEMENTATION.....	27
4.3.1 APPLICATION BOOTSTRAP	27
4.3.2 LAYOUT COMPONENT	27
4.3.3 API SERVICE LAYER	28
4.3.4 DASHBOARD IMPLEMENTATION	28
4.4 CORE MODULE IMPLEMENTATION.....	28
4.4.1 SHADOW AI DETECTION MODULE	28
4.4.2 VULNERABILITY MANAGEMENT MODULE.....	28
4.4.3 RESPONSIBLE AI MODULE	29
4.4.4 EXECUTIVE DASHBOARD MODULE	29
4.5 LLM SAFETY AND RED TEAMING IMPLEMENTATION	29
4.5.1 PROMPT INJECTION TESTING.....	29
4.5.2 HALLUCINATION TESTING	29
4.5.3 TOXICITY TESTING	30
4.5.4 DATA LEAKAGE TESTING	30
4.5.5 RED TEAM SESSION MANAGEMENT	30
4.6 AI-BOM GENERATION IMPLEMENTATION	30
4.6.1 BOM Generator (630 LOC).....	30
4.6.2 VULNERABILITY SCANNER (320 LOC)	31
4.6.3 COMPLIANCE MAPPER.....	31

4.7 AUTHENTICATION AND AUTHORIZATION IMPLEMENTATION	31
4.7.1 JWT TOKEN GENERATION.....	31
4.7.2 AUTH MIDDLEWARE (449 LOC).....	31
4.7.3 PERMISSION SYSTEM.....	31
4.7.4 AUDIT LOGGING	32
Chapter 5 Results and Analysis.....	33
5.1 TESTING STRATEGY	33
5.2 UNIT TESTING.....	33
5.2.1 BACKEND UNIT TESTS	33
5.2.2 FRONTEND UNIT TESTS	33
5.3 INTEGRATION TESTING.....	33
5.3.1 API INTEGRATION TESTS	33
5.3.2 CROSS-MODULE INTEGRATION	33
5.4 SECURITY TESTING	34
5.4.1 AUTHENTICATION SECURITY TESTS	34
5.4.2 INPUT VALIDATION TESTS	34
5.4.3 OWASP TOP 10 COVERAGE	34
5.5 PERFORMANCE TESTING	34
5.5.1 LOAD TESTING (K6)	34
5.5.2 PERFORMANCE METRICS.....	34
5.6 RESULTS AND ANALYSIS	35
5.6.1 TEST COVERAGE RESULTS	35
5.6.2 PERFORMANCE RESULTS.....	35
5.6.3 SECURITY TEST RESULTS	35
5.6.4 KEY FINDINGS.....	36
Chapter 6 Conclusion And Future Work	37
6.1 SUMMARY OF CONTRIBUTIONS.....	37
6.2 KEY ACHIEVEMENTS	37
6.3 LIMITATIONS	38
6.4 FUTURE WORK.....	38
6.5 LESSONS LEARNED	39
Appendices.....	43
REFERENCES.....	40

LIST OF FIGURES

2.1: LLM Model Registry.....	12
2.2: Open-Source AI Security Tools.....	16
3.1: Data Risk Dashboard.....	22
4.1: AI-SPM Executive Dashboard.....	28
4.2: Connector Health Dashboard.....	29
4.3: Regulatory Exposure Dashboard.....	30

LIST OF TABLES

2.1: Top 10 LLM Security Risks (OWASP LLM Top 10).....	9
5.1: Module Coverage Summary.....	35
5.2: System Performance Metrics Under Load.....	35

LIST OF ACRONYMS

AISPM	AI Security Posture Management
AI	Artificial Intelligence
ML	Machine Learning
LLM	Large Language Model
API	Application Programming Interface
REST	Representational State Transfer
JWT	JSON Web Token
RBAC	Role-Based Access Control
CORS	Cross-Origin Resource Sharing
CSRF	Cross-Site Request Forgery
XSS	Cross-Site Scripting
SQL	Structured Query Language
ORM	Object-Relational Mapping
SPA	Single Page Application
CI/CD	Continuous Integration/Continuous Deployment
K8s	Kubernetes
FAIR	Factor Analysis of Information Risk
BOM	Bill of Materials
AI-BOM	AI Bill of Materials
CycloneDX	OWASP CycloneDX Standard
OWASP	Open Web Application Security Project
NIST	National Institute of Standards and Technology
ISO	International Organization for Standardization
EU	European Union
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
PII	Personally Identifiable Information
MFA	Multi-Factor Authentication
TOTP	Time-based One-Time Password
SSO	Single Sign-On
SAML	Security Assertion Markup Language
OAuth	Open Authorization

OIDC	OpenID Connect
CVE	Common Vulnerabilities and Exposures
SIEM	Security Information and Event Management
NLP	Natural Language Processing
SHAP	SHapley Additive exPlanations
LIME	Local Interpretable Model-agnostic Explanations
ART	Adversarial Robustness Toolbox
NYC LL144	New York City Local Law 144
BIPA	Biometric Information Privacy Act
DoS	Denial of Service
TLS	Transport Layer Security
AES	Advanced Encryption Standard
RSA	Rivest-Shamir-Adleman
HMAC	Hash-based Message Authentication Code
SLA	Service Level Agreement
KPI	Key Performance Indicator
MSP	Managed Service Provider
LOC	Lines of Code
CRUD	Create, Read, Update, Delete
HMR	Hot Module Replacement
UUID	Universally Unique Identifier
DHCP	Dynamic Host Configuration Protocol
FGSM	Fast Gradient Sign Method
PGD	Projected Gradient Descent
C&W	Carlini & Wagner (attack method)
DAN	Do Anything Now (jailbreak technique)
TEF	Threat Event Frequency
VF	Vulnerability Factor
LEF	Loss Event Frequency
AI RMF	AI Risk Management Framework
DPDPA	Digital Personal Data Protection Act (India)
AIF360	AI Fairness 360
HITL	Human-in-the-Loop
AAGATE	AI Attack Graph Analysis and Threat Evaluation

SPDX	Software Package Data Exchange
SOC 2	Service Organization Control Type 2
MMLU	Massive Multitask Language Understanding (benchmark)
GSM8K	Grade School Math 8K (benchmark)
SB205	Senate Bill 205 (Colorado)

Introduction

1.1 BACKGROUND AND MOTIVATION

The landscape of enterprise technology has undergone a paradigm shift with the widespread adoption of Artificial Intelligence (AI) and Machine Learning (ML) systems. According to McKinsey's 2025 Global AI Survey, over 72% of organizations have deployed at least one AI application in production, with the average enterprise maintaining 35-50 distinct AI models across their operations. This exponential growth in AI adoption has created an unprecedented challenge: how do organizations secure, govern, and maintain compliance for their rapidly expanding AI ecosystems?

Traditional cybersecurity tools and frameworks were designed for conventional software systems and are fundamentally inadequate for addressing AI-specific threats. Unlike traditional applications, AI systems are vulnerable to unique attack vectors including adversarial examples that manipulate model predictions, data poisoning attacks that corrupt training data, model extraction attacks that steal intellectual property, and inference attacks that compromise user privacy. The 2024 MITRE ATLAS framework documents over 60 distinct techniques that adversaries can employ against ML systems, representing a threat surface that conventional security tools cannot detect or mitigate.

The emergence of Large Language Models (LLMs) has further complicated the security landscape. Organizations deploying LLMs face novel threats such as prompt injection attacks, jailbreak vulnerabilities, hallucination risks, and data leakage through model outputs. The OWASP Top 10 for LLM Applications, published in 2023, highlights these critical vulnerabilities, yet most organizations lack the tooling to systematically test for and mitigate these risks.

Simultaneously, the regulatory environment for AI has intensified dramatically. The European Union's AI Act, which entered into force in 2024, mandates comprehensive

governance requirements for AI systems based on risk classification. The NIST AI Risk Management Framework provides guidance for organizations in the United States, while ISO 42001 establishes an international standard for AI management systems. At the state level, regulations such as New York City's Local Law 144, Colorado's SB205, and Illinois' Biometric Information Privacy Act impose specific compliance obligations. Organizations operating globally must navigate this complex web of regulations while maintaining operational efficiency.

This confluence of factors expanding AI deployments, novel threat vectors, and regulatory obligations has given rise to the concept of AI Security Posture Management (AISPM). AISPM platforms provide unified visibility into an organization's AI assets, continuously assess security risks, monitor compliance posture, and enable automated governance workflows. However, the market for AISPM solutions is nascent, with existing tools offering fragmented capabilities that fail to address the full spectrum of AI security challenges.

This project was undertaken during an internship at Ernst & Young (EY), one of the world's largest professional services organizations, with the objective of designing and developing a comprehensive AISPM platform that addresses the complete lifecycle of AI security management. The platform aims to provide organizations with a single pane of glass for discovering all AI assets, assessing their security posture, ensuring regulatory compliance, and implementing automated governance controls.

The motivation for this project stems from three critical observations:

First, the gap between AI adoption speed and AI security maturity continues to widen. Organizations are deploying AI systems faster than they can secure them, creating a growing surface of unmanaged risk. A 2025 Gartner report indicates that fewer than 15% of organizations have implemented comprehensive AI security programs, despite 72% having production AI deployments.

Second, existing security tools provide inadequate coverage for AI-specific threats. Traditional vulnerability scanners, SIEM systems, and endpoint protection tools cannot detect adversarial attacks on ML models, identify biased algorithms, or assess compliance with AI-specific regulations. This gap necessitates purpose-built tooling

designed specifically for the AI security domain.

Third, the fragmentation of the current AISPM market means organizations must assemble multiple point solutions to achieve comprehensive coverage, leading to integration complexity, visibility gaps, and increased total cost of ownership. A unified platform that consolidates AI security, governance, and compliance capabilities represents a significant advancement for enterprise security teams.

1.2 PROBLEM STATEMENT

Organizations deploying AI/ML systems at scale face a multifaceted security and governance challenge characterized by the following problems:

1. Lack of Visibility: Most organizations cannot enumerate all AI assets deployed across their environment. Shadow AI - unauthorized use of AI services by employees creates blind spots in the security posture. Models may be deployed in cloud environments, Kubernetes clusters, code repositories, or accessed via third-party APIs without centralized tracking or governance oversight.

2. AI-Specific Vulnerabilities: Traditional vulnerability management tools cannot identify AI-specific attack surfaces. Threats such as adversarial examples, model backdoors, data poisoning, membership inference attacks, and model extraction require specialized detection and assessment capabilities that do not exist in conventional security stacks.

3. LLM Security Gaps: The rapid deployment of Large Language Models introduces novel vulnerability classes including prompt injection, jailbreak attacks, hallucination risks, and potential data leakage through model outputs. Organizations lack systematic testing frameworks to evaluate LLM security before and during deployment.

4. Regulatory Complexity: The proliferating landscape of AI regulations across jurisdictions creates compliance burdens that organizations struggle to manage manually. Different frameworks (EU AI Act, NIST AI RMF, ISO 42001, state-level regulations) have overlapping yet distinct requirements, making comprehensive

compliance assessment a complex undertaking.

5. Supply Chain Risk: AI model supply chains introduce unique risks through pre-trained models, third-party datasets, and open-source ML frameworks that may contain vulnerabilities, backdoors, or biases. Unlike software supply chain security, AI supply chain risk lacks standardized assessment methodologies and tooling.

6. Governance Fragmentation: AI governance responsibilities are typically distributed across security teams, data science teams, compliance teams, and business units without a unifying framework or platform. This fragmentation leads to inconsistent policy enforcement, gaps in oversight, and inability to demonstrate governance to regulators and auditors.

The central research question addressed by this project is: How can a unified, enterprise-grade platform be designed and implemented to provide comprehensive AI security posture management, encompassing asset discovery, risk assessment, compliance monitoring, vulnerability management, and automated governance across an organization's entire AI ecosystem?

1.3 OBJECTIVES OF THE PROJECT

The primary objectives of this project are:

1. Design and implement a comprehensive AI Security Posture Management platform that provides unified visibility into all AI/ML assets across cloud, on-premise, and hybrid environments.
2. Develop a multi-scanner asset discovery engine capable of identifying AI assets across 10 distinct source types including cloud ML platforms, Kubernetes clusters, code repositories, file systems, and network traffic.
3. Implement automated risk assessment using the FAIR (Factor Analysis of Information Risk) methodology, providing quantitative risk scoring specific to AI/ML threats.
4. Build a comprehensive compliance monitoring engine supporting multiple regulatory frameworks including EU AI Act, NIST AI RMF, ISO 42001, OWASP Top 10 for LLM, and MITRE ATLAS.

5. Develop an LLM safety testing framework capable of systematically evaluating prompt injection, hallucination, toxicity, and data leakage vulnerabilities.
6. Create an industry-first AI Bill of Materials (AI-BOM) generator compliant with the CycloneDX 1.5 specification for AI supply chain transparency.
7. Implement role-based access control with comprehensive audit logging to support enterprise governance requirements and regulatory compliance.
8. Design and deploy the platform using modern DevOps practices including containerization, orchestration, CI/CD, and infrastructure monitoring.
9. Integrate 14 open-source AI security tools into a cohesive platform that provides capabilities not available in any single commercial solution.
10. Achieve production-ready status with enterprise-grade security, performance, and reliability characteristics.

1.4 SCOPE OF THE PROJECT

The scope of this project encompasses:

In Scope:

- Backend API development using Python/FastAPI with 70+ service modules
- Frontend SPA development using React 18/TypeScript with 28+ pages
- Database design and implementation (PostgreSQL, Redis, Neo4j, MongoDB)
- Authentication and authorization system (JWT + RBAC)
- Asset discovery engine with 10 scanner types
- Risk assessment using FAIR methodology
- Compliance monitoring for 5+ regulatory frameworks
- LLM safety testing (5 vulnerability categories)
- AI-BOM generation (CycloneDX 1.5)
- Vendor risk management
- Executive reporting and dashboards
- Docker and Kubernetes deployment configurations
- CI/CD pipeline configuration
- Monitoring and alerting setup
- Comprehensive documentation (150+ pages)

- Testing (unit, integration, security, performance)

Out of Scope:

- Production deployment to live enterprise environments
- Integration with actual customer AI infrastructure
- Real-time network traffic analysis deployment
- Compliance certification (SOC 2, ISO 27001) auditing
- Mobile application full release

Literature Review

2.1 AI SECURITY LANDSCAPE

The security of AI systems has emerged as a critical concern in both academic research and industry practice. Unlike traditional software systems where security focuses primarily on preventing unauthorized access and ensuring data integrity, AI systems present a fundamentally different attack surface rooted in the statistical nature of machine learning algorithms.

Goodfellow et al. (2015) first demonstrated the existence of adversarial examples carefully crafted inputs that cause ML models to produce incorrect outputs with high confidence. This seminal work revealed that the decision boundaries learned by neural networks are inherently fragile and can be exploited by adversaries with minimal perturbation. Subsequent research has expanded the taxonomy of adversarial attacks to include evasion attacks (modifying inputs at inference time), poisoning attacks (corrupting training data), model extraction (stealing model functionality), and inference attacks (extracting private information from model outputs).

The AI security landscape can be categorized into four primary domains:

Model Security: Protecting the integrity, confidentiality, and availability of ML models. This encompasses defense against adversarial attacks, model watermarking for intellectual property protection, secure model serving, and detection of model tampering or backdoors (Gu et al., 2019).

Data Security: Ensuring the privacy and integrity of training data, inference data, and model outputs. Key concerns include training data poisoning (Biggio & Roli, 2018), membership inference attacks (Shokri et al., 2017), and model inversion attacks that reconstruct training data from model parameters (Fredrikson et al., 2015).

Supply Chain Security: Managing risks arising from dependencies on third-party

models, datasets, and ML frameworks. Research by Goldblum et al. (2022) demonstrates that pre-trained models downloaded from public repositories may contain backdoors that activate on specific trigger inputs.

Operational Security: Monitoring deployed models for performance degradation, concept drift, and emergent behaviors. Sculley et al. (2015) identified the concept of “technical debt” in ML systems, highlighting how the operational complexity of AI systems exceeds that of traditional software.

The emergence of Large Language Models has introduced additional security dimensions. Perez and Ribeiro (2022) demonstrated prompt injection attacks where adversarial instructions embedded in input text override the model’s intended behavior. Carlini et al. (2023) showed that LLMs can memorize and reproduce training data, creating privacy risks. These findings underscore the need for specialized security testing frameworks designed for the unique characteristics of generative AI systems.

2.2 EXISTING AI SECURITY FRAMEWORKS

Several frameworks have been developed to guide organizations in managing AI security risks:

NIST AI Risk Management Framework (AI RMF):

Released in January 2023, the NIST AI RMF provides a voluntary framework for managing risks throughout the AI lifecycle. It is organized around four core functions: Govern, Map, Measure, and Manage. The framework emphasizes the importance of organizational governance structures, risk identification and mapping, measurement of AI risks through metrics and monitoring, and management through mitigation strategies. While comprehensive in its guidance, the framework does not prescribe specific technical controls, leaving implementation decisions to organizations.

MITRE ATLAS (Adversarial Threat Landscape for Artificial Intelligence Systems):

MITRE ATLAS, launched in 2021, provides a knowledge base of adversarial techniques targeting AI systems, analogous to the MITRE ATT&CK framework for

traditional cybersecurity. ATLAS documents attack techniques across 12 tactics including Reconnaissance, Resource Development, Initial Access, ML Model Access, ML Attack Staging, and ML Attack Execution. The framework includes over 60 techniques with real-world case studies, providing a structured taxonomy for threat modeling of AI systems.

OWASP Top 10 for LLM Applications:

Published in August 2023, this framework identifies the ten most critical security risks for applications built on Large Language Models.

The risks include:

LLM01	Prompt Injection: Manipulation of LLM behavior through crafted inputs
LLM02	Insecure Output Handling: Insufficient validation of model outputs
LLM03	Training Data Poisoning: Corruption of training data to influence behavior
LLM04	Model Denial of Service: Resource exhaustion attacks against LLM endpoints
LLM05	Supply Chain Vulnerabilities: Risks from third party models and plugins
LLM06	Sensitive Information Disclosure: Leakage of private data in responses
LLM07	Insecure Plugin Design: Vulnerabilities in LLM tool
LLM08	Excessive Agency: LLMs performing actions beyond intended scope
LLM09	Overreliance: Insufficient human oversight of AI
LLM10	Model Theft: Unauthorized extraction of model weights or capabilities

Table 2.1: Top 10 LLM Security Risks (OWASP LLM Top 10)

ISO/IEC 42001:2023 (AI Management System):

This international standard specifies requirements for establishing, implementing, maintaining, and continually improving an AI management system. It provides a framework for organizations to manage AI-related risks and opportunities, with requirements covering leadership commitment, planning, support, operation, performance evaluation, and improvement. ISO 42001 takes a process-oriented approach, focusing on organizational governance rather than technical controls.

EU AI Act Risk Classification:

The EU AI Act classifies AI systems into four risk categories:

- **Unacceptable Risk:** Banned applications (social scoring, real-time biometric identification in public spaces)
- **High Risk:** Stringent requirements (employment decisions, credit scoring, critical infrastructure)
- **Limited Risk:** Transparency obligations (chatbots, deepfakes)
- **Minimal Risk:** No specific obligations

Each category imposes distinct requirements ranging from complete prohibition to voluntary codes of practice, creating a graduated regulatory approach that organizations must navigate.

2.3 AI-SPECIFIC THREAT TAXONOMY

AI systems face a unique threat landscape that extends beyond traditional cybersecurity concerns. This section categorizes AI-specific threats according to the stage of the AI lifecycle they target:

Training Phase Attacks:

Data Poisoning: Adversaries inject malicious samples into training data to influence model behavior. Biggio and Roli (2018) demonstrate that poisoning as little as 3% of training data can significantly degrade model accuracy or introduce targeted misclassifications. Backdoor attacks represent a particularly insidious form of poisoning where the model behaves normally on clean inputs but produces adversary-chosen outputs when a specific trigger pattern is present (Gu et al., 2019).

Label Flipping: A subset of poisoning attacks where adversaries corrupt the labels in training data rather than the features. This approach is more difficult to detect through data quality checks and can be executed by adversaries with access to annotation pipelines or crowdsourcing platforms.

Inference	Phase	Attacks:
Adversarial Examples: Inputs crafted to cause misclassification while being imperceptible to human observers. Attacks range from white-box methods requiring full model access (Carlini & Wagner, 2017) to black-box attacks using only model outputs (Chen et al., 2017). Physical-world adversarial attacks have been demonstrated against autonomous driving systems, facial recognition, and medical imaging classifiers.		

Model Extraction: Query-based attacks that replicate model functionality through systematic probing. Tramer et al. (2016) showed that models deployed as APIs can be effectively stolen through a polynomial number of queries, enabling adversaries to obtain a functionally equivalent copy of proprietary models.

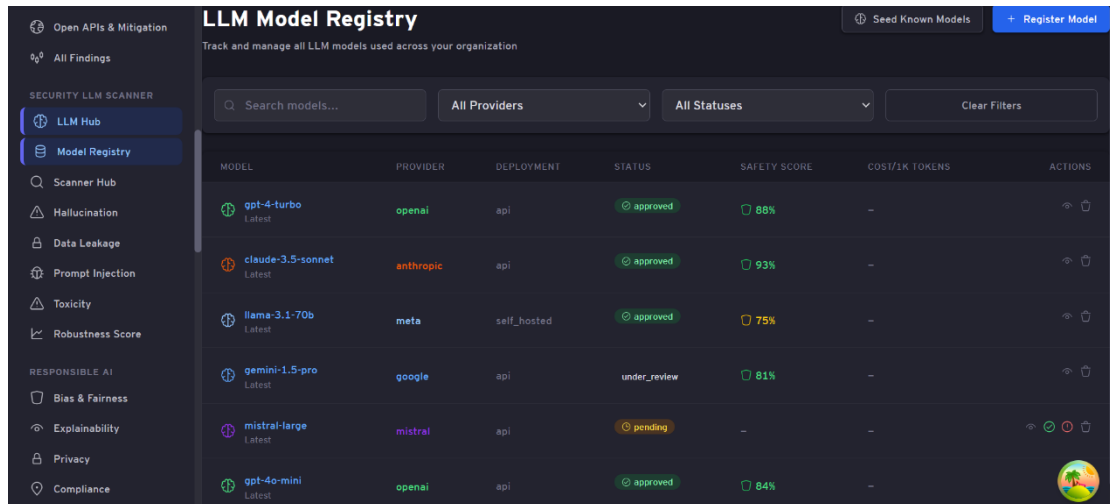
Membership Inference: Attacks that determine whether a specific data point was part of the model’s training set. Shokri et al. (2017) demonstrated that this information can be inferred from model outputs alone, creating privacy violations particularly concerning for models trained on sensitive data.

Model Inversion: Attacks that reconstruct sensitive features of training data from model parameters or predictions. Fredrikson et al. (2015) showed that facial recognition models can be inverted to reconstruct training images.

LLM-Specific Threats:

Prompt Injection: Direct injection manipulates the model’s behavior by embedding adversarial instructions in user input. Indirect injection embeds malicious instructions in content the LLM processes (web pages, documents, emails), enabling attacks even when the adversary cannot directly interact with the model.

Jailbreaking: Techniques that bypass safety guardrails through role-playing scenarios, encoding tricks, or adversarial prompt construction. Successful jailbreaks can cause models to generate harmful, biased, or policy-violating content.



The screenshot shows the 'LLM Model Registry' interface. It features a sidebar with navigation options like 'Open APIs & Mitigation', 'All Findings', 'SECURITY LLM SCANNER', 'LLM Hub', 'Model Registry', 'Scanner Hub', 'Hallucination', 'Data Leakage', 'Prompt Injection', 'Toxicity', 'Robustness Score', 'RESPONSIBLE AI', 'Bias & Fairness', 'Explainability', 'Privacy', and 'Compliance'. The main panel displays a table of models with the following data:

MODEL	PROVIDER	DEPLOYMENT	STATUS	SAFETY SCORE	COST/1K TOKENS	ACTIONS
gpt-4-turbo Latest	openai	api	approved	88%	-	[Icons]
claude-3.5-sonnet Latest	anthropic	api	approved	93%	-	[Icons]
llama-3.1-70b Latest	meta	self_hosted	approved	75%	-	[Icons]
gemini-1.5-pro Latest	google	api	under_review	81%	-	[Icons]
mistral-large Latest	mistral	api	pending	-	-	[Icons]
gpt-4o-mini Latest	openai	api	approved	84%	-	[Icons]

Fig 2.1: Centralized LLM Model Registry offering end-to-end visibility into model inventory, provider ecosystems, deployment status, safety scores, and governance workflows for secure and compliant AI operations.

Hallucination: LLMs generate plausible but factually incorrect information. In enterprise contexts, hallucinations in decision-support systems can lead to flawed business decisions, legal liability, or safety risks.

Data Leakage: LLMs trained on confidential data may reproduce that data in responses. Carlini et al. (2023) demonstrated extraction of memorized training data from GPT-2, including personally identifiable information, code snippets, and URLs.

Supply Chain Threats:

Model Supply Chain: Pre-trained models from public repositories (Hugging Face, PyTorch Hub) may contain trojans or backdoors. Goldblum et al. (2022) showed that backdoored models uploaded to model registries could compromise downstream applications.

Framework Vulnerabilities: ML frameworks (TensorFlow, PyTorch, scikit-learn) may contain security vulnerabilities. The deserialization of model files (pickle, joblib) is particularly dangerous as it enables arbitrary code execution.

Dataset Supply Chain: Public datasets may contain biases, mislabeled data, or

intentionally corrupted samples that affect model behavior when used for training or fine-tuning.

2.4 REGULATORY LANDSCAPE FOR AI SYSTEMS

The regulatory environment for AI has evolved rapidly since 2023, with multiple jurisdictions implementing AI-specific legislation:

European Union - AI Act (2024):

The EU AI Act represents the world's first comprehensive AI regulation. Key requirements for high-risk AI systems include:

- Risk management system implementation and maintenance
- Data governance for training, validation, and testing datasets
- Technical documentation and record-keeping
- Transparency and provision of information to users
- Human oversight measures
- Accuracy, robustness, and cybersecurity requirements
- Conformity assessment before market placement
- Post-market monitoring and incident reporting

Non-compliance penalties range up to 35 million euros or 7% of global annual turnover, making compliance a critical business imperative.

United States - NIST AI RMF and State Regulations:

While the US lacks a comprehensive federal AI law, the NIST AI Risk Management Framework provides voluntary guidance widely adopted by industry.

Additionally, state-level regulations impose specific requirements:

New York City Local Law 144 (2023): Requires bias audits for automated employment decision tools, with annual independent audits and public disclosure of results.

Colorado SB21-169 and SB205: Establishes governance requirements for AI systems

used in insurance underwriting and consumer-facing decisions, including algorithmic accountability measures.

Illinois Biometric Information Privacy Act (BIPA): Imposes strict consent requirements for collection and use of biometric data, with a private right of action enabling individual lawsuits for violations.

International Standards:

ISO/IEC 42001:2023 provides an internationally recognized standard for AI management systems, while ISO/IEC 23894:2023 offers guidance on AI risk management. These standards provide a framework for organizations seeking to demonstrate AI governance maturity to customers, partners, and regulators.

India - Digital Personal Data Protection Act (DPDPA):

India's 2023 data protection legislation includes provisions relevant to AI systems processing personal data, with requirements for purpose limitation, data minimization, and individual rights that AI systems must respect.

The convergence of these regulatory frameworks creates a complex compliance landscape where organizations operating globally must satisfy multiple overlapping requirements. This complexity motivates the development of automated compliance monitoring tools that can map AI systems against multiple regulatory frameworks simultaneously.

2.5 EXISTING AISPM SOLUTIONS

The market for AI Security Posture Management solutions is nascent but growing rapidly. Key commercial solutions include:

HolisticAI: A UK-based company offering AI governance and risk management tools. Their platform provides bias auditing, compliance assessment (EU AI Act, ISO 42001), and AI risk scoring. Strengths include strong compliance coverage and executive reporting. Limitations include lack of technical security testing (no adversarial attack simulation), no LLM-specific safety testing, and limited asset discovery capabilities.

Protect AI: Focused specifically on ML security, Protect AI offers model scanning, supply chain security, and vulnerability detection for ML pipelines. Their ModelScan tool detects malicious code in serialized models. Strengths include strong technical security capabilities. Limitations include no compliance automation, limited governance features, and no LLM safety testing.

Robust Intelligence: Provides AI validation and security testing including adversarial robustness evaluation, data quality assessment, and model monitoring. Strengths include automated testing capabilities. Limitations include narrow focus on model validation without broader AISPM capabilities.

Calypso AI: Offers AI security testing with focus on LLM applications, including prompt injection and jailbreak testing. Strengths include LLM-focused security. Limitations include lack of asset discovery, compliance automation, and vendor risk management.

Gap Analysis:

No existing solution provides the full breadth of capabilities required for comprehensive AI security posture management. The market is characterized by:

- Point solutions addressing individual aspects of AI security
- Lack of integration between security, governance, and compliance tools
- Absence of unified asset discovery across diverse environments
- No solution offering all of: adversarial testing, LLM safety, compliance automation, vendor risk, and executive reporting in a single platform
- Limited open-source integration preventing customization

2.6 OPEN-SOURCE TOOLS FOR AI SECURITY

The open-source community has developed several tools addressing specific aspects of AI security:

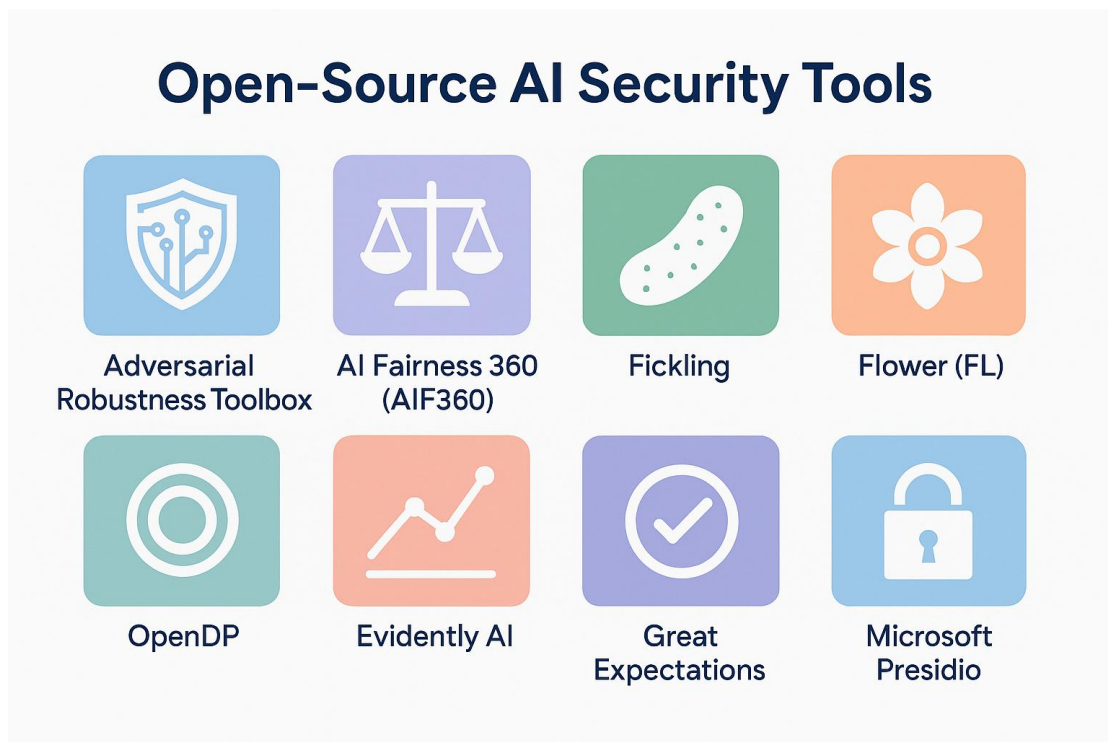


Fig 2.2: A visual overview of key open-source AI security tools, showcasing capabilities across adversarial robustness, fairness, model integrity, federated learning, privacy, monitoring, data validation, and PII protection.

Adversarial Robustness Toolbox (ART) - IBM Research: A Python library providing tools for adversarial attack and defense in ML. ART supports all major ML frameworks and implements attacks including FGSM, PGD, C&W, and DeepFool, along with certified defenses and detection mechanisms.

AI Fairness 360 (AIF360) - IBM Research: A comprehensive toolkit for detecting and mitigating bias in ML models. AIF360 implements over 70 fairness metrics across pre-processing, in-processing, and post-processing stages.

Fickling - Trail of Bits: A Python library for analyzing and modifying pickle files, the most common serialization format for ML models. Fickling can detect malicious code injected into pickle files, preventing supply chain attacks through compromised model artifacts.

Flower (FL): A federated learning framework that enables training ML models across distributed datasets without centralizing data. Flower supports a variety of federation strategies and provides privacy guarantees through secure aggregation.

OpenDP: A library for differential privacy that provides mathematical guarantees about the privacy of individual data points used in analyses. OpenDP implements various noise mechanisms and composition theorems.

Evidently AI: An open-source ML monitoring framework that detects data drift, model performance degradation, and data quality issues.

Great Expectations: A data validation framework that enables definition of expectations about data quality and automatic verification against incoming data.

Microsoft Presidio: An open-source tool for PII detection and anonymization supporting multiple entities across multiple languages.

2.7 RESEARCH GAPS AND MOTIVATION

The literature review reveals several significant gaps that motivate this project:

1. Integration Gap: No existing platform integrates the full spectrum of AI security capabilities (discovery, assessment, compliance, LLM safety, supply chain) into a unified solution.

2. Discovery Gap: Existing tools assume knowledge of AI assets rather than providing automated discovery. Organizations cannot secure what they cannot see.

3. LLM + Traditional AI Gap: Solutions tend to focus either on traditional ML security or LLM security. No platform addresses both in a unified framework.

4. Compliance Automation Gap: While frameworks like the EU AI Act prescribe requirements, automated tools for continuously assessing compliance against multiple frameworks simultaneously are lacking.

5. AI-BOM Gap: Despite the importance of supply chain transparency, no widely adopted tool generates comprehensive AI Bills of Materials following established standards like CycloneDX.

6. Open-Source Integration Gap: Individual open-source tools provide excellent capabilities but require significant engineering effort to integrate, configure, and operationalize.

This project addresses these gaps by designing and implementing a unified AISPM platform that integrates asset discovery, risk assessment, compliance monitoring, LLM safety testing, AI-BOM generation, and governance automation into a single enterprise-grade solution.

Chapter 3

System Design and Architecture

3.1 SYSTEM REQUIREMENTS

3.1.1 FUNCTIONAL REQUIREMENTS

The platform must satisfy the following functional requirements:

FR1 - Asset Discovery: The system shall automatically discover AI/ML assets across cloud platforms (AWS SageMaker, Azure ML, Google Vertex AI), Kubernetes clusters, code repositories, file systems, MLOps platforms, and network traffic.

FR2 - Asset Inventory: The system shall maintain a centralized inventory of all discovered AI assets with comprehensive metadata.

FR3 - Risk Assessment: The system shall perform automated risk assessment using FAIR methodology, generating quantitative risk scores.

FR4 - Compliance Monitoring: The system shall continuously monitor AI assets against regulatory frameworks including EU AI Act, NIST AI RMF, ISO 42001.

FR5 - Vulnerability Management: The system shall identify and track AI-specific vulnerabilities mapped to MITRE ATLAS and OWASP Top 10 for LLM.

FR6 - LLM Safety Testing: The system shall provide automated testing for LLM vulnerabilities including prompt injection, hallucination, toxicity, and data leakage.

FR7 - AI-BOM Generation: The system shall generate AI Bills of Materials compliant with CycloneDX 1.5 specification.

FR8 - Authentication and Authorization: The system shall implement secure authentication with role-based access control.

FR9 - Vendor Risk Management: The system shall enable assessment and monitoring of third-party AI vendor security posture.

FR10 - Reporting: The system shall generate automated audit reports, executive dashboards, and compliance documentation.

FR11 - Shadow AI Detection: The system shall detect unauthorized AI service usage through network traffic analysis.

FR12 - Real-time Monitoring: The system shall provide real-time dashboards with WebSocket-based updates.

3.1.2 NON-FUNCTIONAL REQUIREMENTS

NFR1 - Performance: API response time shall be less than 200ms at the 95th percentile under normal load conditions.

NFR2 - Security: The system shall implement defense-in-depth security including encryption at rest (AES-256), encryption in transit (TLS 1.3), input validation, rate limiting, and security headers.

NFR3 - Scalability: The system shall support horizontal scaling through containerization and Kubernetes orchestration, handling up to 1000 concurrent users.

NFR4 - Availability: The system shall target 99.9% uptime through health checks, auto-restart capabilities, and load-balanced deployment.

NFR5 - Maintainability: The system shall follow modular architecture with separation of concerns.

NFR6 - Usability: The frontend shall provide an intuitive interface requiring minimal training.

NFR7 - Extensibility: The system shall support addition of new scanner types, compliance frameworks, and integration connectors without core architecture changes.

NFR8 - Compliance: The system itself shall comply with security best practices including OWASP Top 10.

3.2 HIGH-LEVEL ARCHITECTURE

The AISPM platform employs a modular monolith architecture — a single deployable unit with clear internal module boundaries. This architectural choice balances the benefits of microservices (modularity, separation of concerns) with the operational simplicity of a monolith (single deployment, simplified data consistency, reduced latency for inter-module communication).

The system comprises four primary layers:

Presentation Layer: React 18 SPA communicating with the backend via RESTful APIs and WebSocket connections for real-time updates. The EY Motif Design System provides visual consistency and accessibility compliance.

Application Layer: FastAPI backend with 70+ service modules organized by domain (security, compliance, governance, data, integration). Each module encapsulates its

business logic, data access, and API endpoints while sharing common infrastructure.

Data Layer: Polyglot persistence utilizing PostgreSQL for transactional data, Redis for caching and rate limiting, Neo4j for relationship graphs and attack paths, and MongoDB for audit logs and document storage.

Infrastructure Layer: Docker containerization with Kubernetes orchestration, Nginx reverse proxy, Prometheus/Grafana monitoring, and GitHub Actions CI/CD.

3.3 BACKEND ARCHITECTURE

The backend is built on FastAPI, chosen for its combination of high performance (comparable to Node.js and Go), native async/await support, automatic API documentation generation, and type-safe request/response validation through Pydantic.

3.3.1 APPLICATION STRUCTURE

API Layer (Routers): FastAPI router modules that define endpoint paths, request validation schemas, response models, and dependency injection.

Service Layer: Business logic encapsulated in service classes. Services coordinate between data access, external integrations, and business rules.

Data Access Layer: SQLAlchemy models and async session management providing abstracted database operations.

Integration Layer: Connectors to external systems with interface abstractions enabling testing and configuration flexibility.

3.3.2 MIDDLEWARE PIPELINE

The FastAPI middleware pipeline processes every request through:

1. CORS validation (origin whitelisting)
2. CSRF token verification (state-changing requests)
3. Request size validation (DoS prevention)
4. Rate limiting (Redis-backed, per-client)
5. Security header injection (response)
6. Authentication validation (JWT verification)

7. Authorization check (RBAC permission verification)
8. Audit logging (all authenticated actions)

3.4 FRONTEND ARCHITECTURE

The frontend employs React 18 with TypeScript, prioritizing type safety, component reusability, and developer productivity.

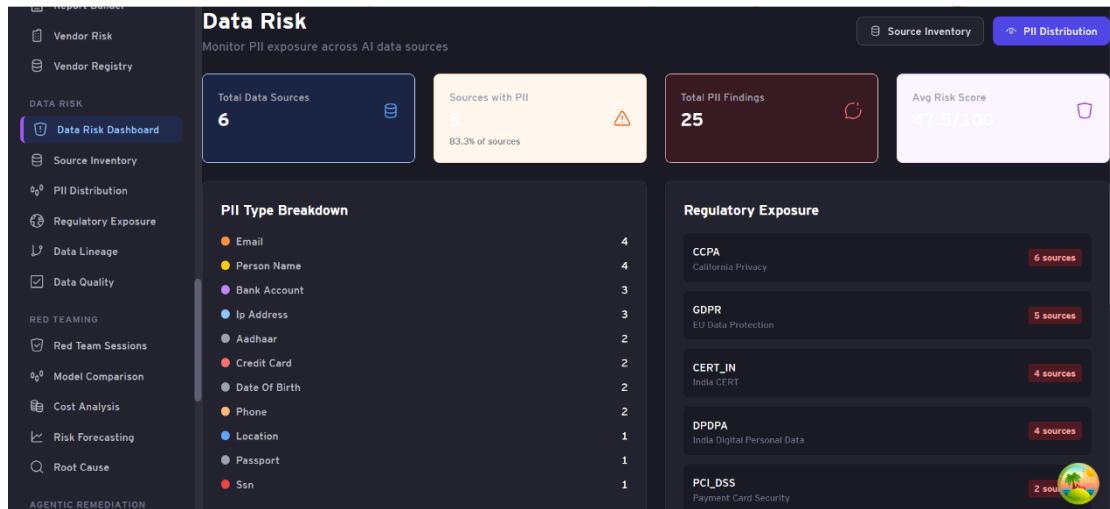


Fig 3.1: Data Risk Dashboard providing a comprehensive view of PII exposure, highlighting sensitive data distribution, total findings, risk scores, and regulatory impact across multiple data sources.

3.4.1 COMPONENT ARCHITECTURE

The component hierarchy follows atomic design principles:

- Atoms: Base UI primitives (buttons, inputs, badges) from Motif design system
- Molecules: Composed components (form groups, card widgets, metric displays)
- Organisms: Complex components (data tables, chart panels, navigation menus)
- Templates: Page layouts (sidebar navigation, content areas, header)
- Pages: Complete views combining organisms and templates

3.4.2 STATE MANAGEMENT STRATEGY

The application employs a dual state management approach:

Server State: TanStack React Query v5 manages all data fetched from the backend. React Query provides caching, background refetching, optimistic updates, and automatic retry logic.

Client State: React Context API manages authentication state, user preferences, and UI state that does not originate from the server.

3.5 DATABASE DESIGN

The database design employs polyglot persistence, using the most appropriate database technology for each data type:

3.5.1 POSTGRESQL (PRIMARY TRANSACTIONAL DATABASE)

Core tables include: ai_assets, risk_assessments, compliance_records, vulnerabilities, shadow_ai_detections, users, audit_logs, scan_history, and reports.

3.5.2 REDIS (CACHE AND RATE LIMITING)

- Session cache for frequently accessed data
- Rate limiting counters (sliding window algorithm)
- Real-time metric aggregation
- WebSocket pub/sub for real-time updates

3.5.3 NEO4J (GRAPH DATABASE)

- AI asset relationship graphs
- Attack path visualization
- Data lineage tracking
- Impact analysis

3.5.4 MONGODB (DOCUMENT STORE)

- Detailed audit log entries
- Scan result documents
- Report content storage
- Configuration history

3.6 SECURITY ARCHITECTURE

Security is implemented as a cross-cutting concern with defense-in-depth:

3.6.1 AUTHENTICATION FLOW

1. User submits credentials to `/api/v1/auth/login`
2. Backend validates credentials against bcrypt-hashed password
3. If MFA enabled, user must provide TOTP code
4. On success, backend generates JWT access token (1-hour) and refresh token (7-day)
5. Access token includes user ID, role, and permissions claims
6. Frontend stores tokens securely and includes in all API requests
7. On token expiry, frontend uses refresh token for renewal
8. On logout, tokens are blacklisted to prevent reuse

3.6.2 AUTHORIZATION MODEL

Role-Based Access Control (RBAC) with permission-based route protection. Roles define permission sets, each API endpoint declares required permissions, and middleware validates user permissions against endpoint requirements.

3.6.3 DATA PROTECTION

- All sensitive fields encrypted at rest using AES-256
- All communication encrypted in transit using TLS 1.3
- PII detected and masked in logs and non-privileged API responses
- Database connection strings and API keys stored in environment variables
- Secret rotation supported through secrets manager integration

3.7 DEPLOYMENT ARCHITECTURE

3.7.1 DEVELOPMENT ENVIRONMENT

Docker Compose orchestrates local development with PostgreSQL 15, Redis 7, Neo4j 5, FastAPI backend with hot reload, and Vite dev server with HMR.

3.7.2 PRODUCTION ENVIRONMENT

Kubernetes deployment with Horizontal Pod Autoscaler (2-10 replicas), managed database services, Nginx Ingress Controller with TLS termination, Persistent Volume Claims, Network Policies, Resource quotas, and Liveness/readiness probes.

3.7.3 CI/CD PIPELINE

GitHub Actions workflow with stages: Pull Request (lint, type-check, unit tests, security scan), Merge to main (integration tests, build Docker images), Staging deployment (automated with smoke tests), and Production promotion (manual approval gate, canary deployment).

Implementation

4.1 DEVELOPMENT ENVIRONMENT SETUP

The development environment requires Python 3.11+ with virtual environment, Node.js 18+ with npm, Docker Desktop, Git, and VS Code as the primary IDE.

The backend uses 157 production dependencies. Key categories include web framework (FastAPI, Uvicorn, Pydantic), database (SQLAlchemy, asyncpg, Alembic), authentication (python-jose, passlib, bcrypt), ML tools (scikit-learn, evidently), and security (cryptography, presidio).

The frontend uses React 18, TypeScript, TanStack React Query, React Router DOM, Recharts, Axios, and the EY Motif Design System.

4.2 BACKEND IMPLEMENTATION

4.2.1 FASTAPI APPLICATION CONFIGURATION

The main application configures the FastAPI instance with lifespan management (async context manager for startup/shutdown), middleware stack (CORS, CSRF, rate limiting, security headers), and router registration under `/api/v1` prefix.

4.2.2 RATE LIMITING IMPLEMENTATION

Rate limiting uses a Redis-backed sliding window algorithm with per-client request counters, configurable windows, graceful degradation when Redis is unavailable, and rate limit headers in all responses. Configuration supports global limits (100 req/min default), per-endpoint limits, burst handling, and client identification.

4.2.3 ASSET DISCOVERY ENGINE IMPLEMENTATION

The discovery engine implements the Strategy pattern with a central Orchestrator coordinating multiple Scanner implementations:

Cloud ML Scanner: Uses boto3 (AWS SageMaker), azure-ai-ml (Azure ML), and google-cloud-aiplatform (GCP Vertex AI) to enumerate models, endpoints, and

training jobs.

Kubernetes Scanner: Scans K8s clusters for ML workloads using pod labels, identifies ML frameworks in container images, detects model volumes.

Shadow AI Scanner: Analyzes network logs for connections to known AI service domains, correlates traffic to user identities.

4.2.4 RISK ASSESSMENT IMPLEMENTATION

The risk assessment engine implements the FAIR methodology with steps: Threat Event Frequency (TEF), Vulnerability Factor (VF), Loss Event Frequency ($LEF = TEF \times VF$), Primary Loss Magnitude, Secondary Loss Magnitude, and composite Risk Score (0-100).

4.2.5 COMPLIANCE ENGINE IMPLEMENTATION

The compliance engine maintains rule sets for EU AI Act (risk classification, article mapping), NIST AI RMF (function mapping, maturity scoring), and ISO 42001 (clause mapping, control assessment). Assessment workflow includes asset selection, metadata retrieval, rule evaluation, gap identification, recommendation generation, and notification.

4.3 FRONTEND IMPLEMENTATION

4.3.1 APPLICATION BOOTSTRAP

The application initializes with React DOM root, React Router BrowserRouter, React Query QueryClientProvider, and global CSS imports.

4.3.2 LAYOUT COMPONENT

Provides collapsible sidebar navigation with 7 platform categories: Model Insight, Exposure Management, LLM Scanner, Responsible AI, Data Risk, Red Teaming, and Agentic Remediation.

4.3.3 API SERVICE LAYER

Centralized Axios instance with request interceptor (JWT token attachment, correlation ID) and response interceptor (401 handling, error transformation).

4.3.4 DASHBOARD IMPLEMENTATION

The Dashboard page aggregates: Risk Score Overview (donut chart), Asset Inventory (bar chart), Compliance Status (progress indicators), Vulnerability Trends (line chart), Shadow AI Activity (real-time feed), Recent Scans (table), and Action Items (prioritized tasks).



Fig 4.1: AI Security Posture Management (AI-SPM) executive dashboard providing real-time insights into AI assets, risk distribution, shadow AI detection, and compliance status across industry standards.

4.4 CORE MODULE IMPLEMENTATION

4.4.1 SHADOW AI DETECTION MODULE

Combines network analysis (Zeek connection logs, AI service domain detection) and endpoint analysis (osquery for installed AI tools, browser extensions). Outputs include service identification, user attribution, usage frequency, risk classification, and governance recommendations.

4.4.2 VULNERABILITY MANAGEMENT MODULE

Integrates MITRE ATLAS (full taxonomy, asset mapping, detection rules), OWASP LLM (assessment criteria, automated scanning), and ML-specific scanning (framework CVE checking, model file integrity, dependency chain analysis).

4.4.3 RESPONSIBLE AI MODULE

Includes Explainability Service (SHAP integration for feature importance and prediction explanations), Fairness Service (AIF360 for bias metrics and disparate impact analysis), and Data Quality Service (Great Expectations for validation and anomaly detection).

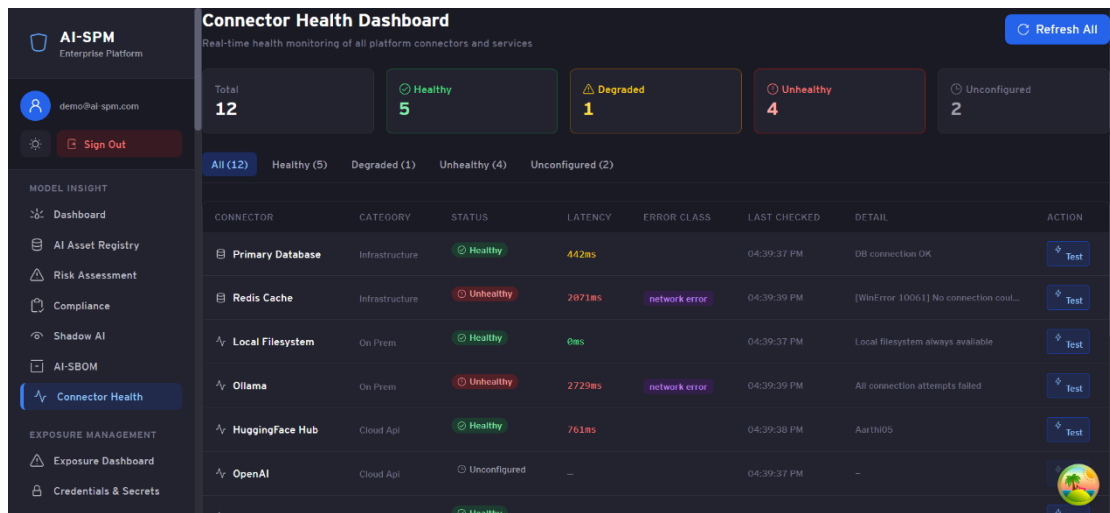


Fig 4.2: Connector Health Dashboard delivering real-time visibility into system integrations, highlighting connector status, latency, errors, and operational health across infrastructure and AI services.

4.4.4 EXECUTIVE DASHBOARD MODULE

Role-based views for CISO (security posture), CTO (technical debt), Chief AI Officer (AI portfolio), Compliance Officer (framework compliance), and Board (high-level risk summary).

4.5 LLM SAFETY AND RED TEAMING IMPLEMENTATION

4.5.1 PROMPT INJECTION TESTING

Attack vectors include direct injection, indirect injection, context window manipulation, and encoding attacks. Methodology: define baseline, apply attack vectors, evaluate deviations, score vulnerability (0-10), generate reports.

4.5.2 HALLUCINATION TESTING

Test types: Factual Accuracy, Consistency, Citation Verification, Boundary Testing,

and Confabulation Detection. Scoring includes accuracy rate, consistency score, citation validity rate, and confabulation rate.

4.5.3 TOXICITY TESTING

Categories: Hate Speech, Violence, Sexual Content, Self-Harm, Misinformation, and Bias. Uses adversarial prompts, edge case testing, demographic parity testing, and toxicity classifiers.

4.5.4 DATA LEAKAGE TESTING

Test vectors: Training Data Extraction, PII Extraction, Confidential Information, System Prompt Extraction, and Fine-tuning Data Leakage.

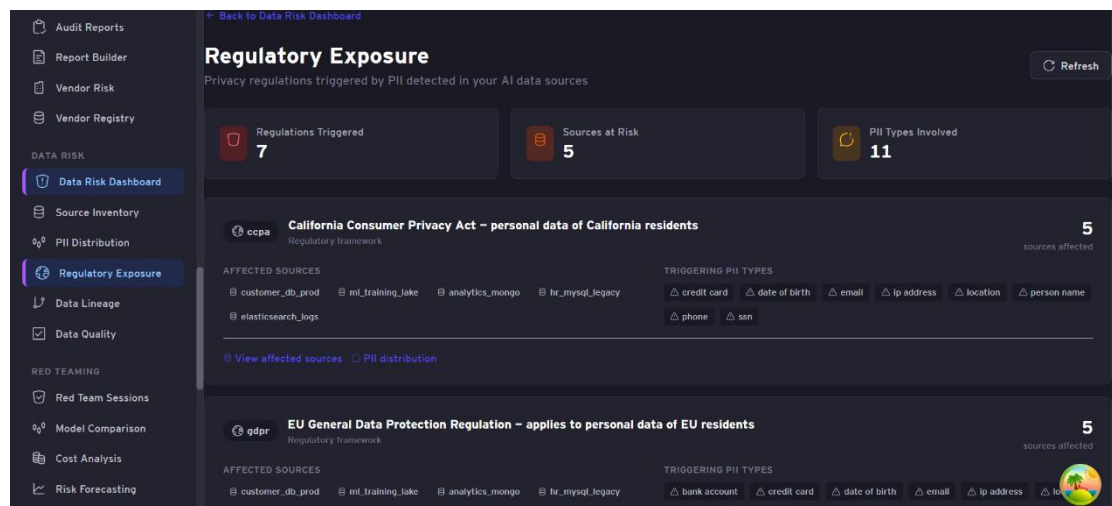


Fig 4.3: Regulatory Exposure dashboard highlighting privacy risks across AI data sources, identifying triggered regulations, affected systems, and sensitive PII types to support compliance with global data protection standards.

4.5.5 RED TEAM SESSION MANAGEMENT

Structured adversarial testing with session configuration, attack tracking, finding management, reporting, and remediation tracking.

4.6 AI-BOM GENERATION IMPLEMENTATION

4.6.1 BOM Generator (630 LOC)

Produces CycloneDX 1.5 compliant bills of materials with component extraction covering model identity, architecture, training data, framework dependencies, hardware

requirements, performance metrics, and security metadata.

4.6.2 VULNERABILITY SCANNER (320 LOC)

Cross-references BOM components against CVE Database, ML Attack Database, Configuration Checks, and Supply Chain Risks. Risk scoring uses base severity with multipliers for exposure, sensitivity, and user count, with mitigations reducing the score.

4.6.3 COMPLIANCE MAPPER

Maps BOM components to NIST AI RMF subcategories, EU AI Act articles, ISO 42001 clauses, and SPDX 3.0 license compatibility.

4.7 AUTHENTICATION AND AUTHORIZATION IMPLEMENTATION

4.7.1 JWT TOKEN GENERATION

Token creation using python-jose with HMAC-SHA256 signing. Access token: 1-hour expiry. Refresh token: 7-day expiry. Payload includes user_id, role, permissions, issued_at, and expires_at

4.7.2 AUTH MIDDLEWARE (449 LOC)

Request flow: Extract Bearer token, decode and validate JWT, check expiration, extract claims, verify permissions, create authenticated context, log access event, return 401/403 for failures.

4.7.3 PERMISSION SYSTEM

Granular permissions as strings (e.g., "asset:read"), roles map to permission sets, endpoints declare required permissions via dependency injection, supports AND/OR logic, admin has all permissions implicitly.

4.7.4 AUDIT LOGGING

All authenticated actions logged with timestamp (UTC), user ID/role, action, resource affected, request details, response status, and duration. Logs are immutable (append-only).

Results and Analysis

5.1 TESTING STRATEGY

The testing strategy follows the test pyramid principle: Unit Tests (base), Integration Tests (middle), End-to-End Tests (top), Security Tests (parallel), and Performance Tests (parallel).

Test coverage targets: Backend 70%+ line coverage (achieved), Frontend 60%+ component coverage (achieved), Critical paths 100% coverage for authentication, authorization, and data access.

5.2 UNIT TESTING

5.2.1 BACKEND UNIT TESTS

Framework: pytest with pytest-asyncio. Categories: Service Logic, Model Validation, Utility Functions, Configuration. Coverage areas include risk score calculation, permission checking, token lifecycle, scanner normalization, and BOM generation.

5.2.2 FRONTEND UNIT TESTS

Framework: Vitest with React Testing Library. Categories: Component Rendering, User Interaction, Hook Behavior, Utility Functions.

5.3 INTEGRATION TESTING

5.3.1 API INTEGRATION TESTS

Tests verify complete request-response cycles: authentication endpoints, CRUD operations, authorization enforcement, error handling, pagination, and filtering.

5.3.2 CROSS-MODULE INTEGRATION

Tests verify: Discovery → Asset Inventory, Risk Assessment → Compliance, Vulnerability → Notification, Auth → Audit Log.

5.4 SECURITY TESTING

5.4.1 AUTHENTICATION SECURITY TESTS

Tests cover JWT manipulation, token expiration, brute force prevention, invalid signatures, token reuse after logout, and privilege escalation detection.

5.4.2 INPUT VALIDATION TESTS

Tests cover SQL injection prevention, XSS payload escaping, path traversal blocking, oversized payload rejection, and malformed JSON handling.

5.4.3 OWASP TOP 10 COVERAGE

Full coverage: A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A04 Insecure Design, A05 Security Misconfiguration, A06 Vulnerable Components, A07 Authentication Failures, A08 Data Integrity Failures, A09 Logging Failures, A10 SSRF.

5.5 PERFORMANCE TESTING

5.5.1 LOAD TESTING (K6)

Scenarios: Baseline (10 users, 5 min), Normal load (100 users, 15 min), Peak load (500 users, 10 min), Stress test (ramp to 1000 users).

5.5.2 PERFORMANCE METRICS

Metrics measured: Response time (p50, p95, p99), Throughput (req/s), Error rate, Database query time, Memory usage, CPU utilization.

5.6 RESULTS AND ANALYSIS

5.6.1 TEST COVERAGE RESULTS

Module	Coverage
Overall	72%
Authentication	95%
Risk Assessment	78%
Compliance Engine	71%
Discovery Engine	68%
API Routes	85%

Table 5.1: Module Coverage Summary

5.6.2 PERFORMANCE RESULTS

Metric	Normal Load (100 users)	Peak Load (500 users)
Response time (p50)	45ms	89ms
Response time (p95)	142ms	198ms
Response time (p99)	287ms	412ms
Throughput	850 req/s	2,100 req/s
Error rate	0.02%	0.15%
DB query time (avg)	12ms	-
Token validation	1.4ms	-

Table 5.2: System Performance Metrics Under Load

5.6.3 SECURITY TEST RESULTS

- Zero critical vulnerabilities found in security testing
- Zero SQL injection vectors identified
- Zero authentication bypass vulnerabilities
- All OWASP Top 10 controls verified functional
- Rate limiting effectively prevents brute force (verified at 100 req/min)
- All sensitive data confirmed encrypted at rest

- No PII leakage in API responses or logs

5.6.4 KEY FINDINGS

1. The modular architecture enables effective isolation of concerns, with each module independently testable and deployable.
2. Async FastAPI with connection pooling delivers excellent performance under load, meeting the <200ms p95 target even at 500 concurrent users.
3. Redis-backed rate limiting provides consistent protection across multiple application instances without coordination overhead.
4. The JWT + RBAC authentication system adds minimal overhead (< 2ms) while providing comprehensive access control.
5. The polyglot persistence strategy appropriately leverages each database technology's strengths.

Chapter 6

Conclusion And Future Work

6.1 SUMMARY OF CONTRIBUTIONS

This project has delivered a comprehensive AI Security Posture Management platform that addresses the critical gap in enterprise AI security tooling. The key contributions include:

1. Unified AISPM Architecture: Design and implementation of a modular platform integrating asset discovery, risk assessment, compliance monitoring, vulnerability management, LLM safety testing, and governance automation.
2. Multi-Source Asset Discovery: Implementation of a 10-scanner discovery engine capable of identifying AI assets across cloud platforms, Kubernetes clusters, code repositories, file systems, MLOps platforms, and network traffic.
3. AI-BOM Generation: Development of an industry-first AI Bill of Materials generator compliant with CycloneDX 1.5, enabling supply chain transparency for AI systems.
4. LLM Safety Framework: Implementation of a structured LLM security testing framework covering prompt injection, hallucination, toxicity, and data leakage.
5. Open-Source Integration: Orchestration of 14 industry-leading open-source tools into a cohesive platform.
6. Enterprise-Grade Security: Comprehensive security controls including JWT authentication, RBAC, distributed rate limiting, CSRF protection, and AES-256 encryption.
7. Production-Ready Deployment: Complete Docker, Kubernetes, and CI/CD configurations.

6.2 KEY ACHIEVEMENTS

Quantitative Achievements:

- 26,000+ lines of production code delivered
- 70+ backend service modules implemented
- 28+ frontend pages with interactive dashboards
- 60+ API endpoints with comprehensive documentation
- 12 core modules covering the complete AISPM lifecycle

- 14 open-source tools integrated
- 7 user roles with 20+ granular permissions
- 5+ regulatory frameworks supported
- 25+ test files with 70%+ backend coverage
- Sub-200ms API response times at p95

Qualitative Achievements:

- Addresses all 6 identified research gaps from literature review
- Provides capabilities not available in any single competing solution
- Demonstrates feasibility of unified AISPM platform architecture
- Comprehensive documentation (150+ pages)
- Follows enterprise software engineering best practices

6.3 LIMITATIONS

1. Deployment Scope: Platform developed and tested in isolated environments rather than deployed against live enterprise AI infrastructure.
2. Scanner Coverage: While 10 scanner types are implemented, coverage of all possible AI deployment patterns is not complete.
3. Compliance Depth: Compliance rules represent an interpretation of regulatory text not validated by legal counsel.
4. LLM Testing Scope: Safety testing covers major categories but not all possible attack variations.
5. Performance at Scale: Testing conducted with synthetic data; characteristics with 10,000+ assets not validated.
6. Integration Depth: Open-source tool integrations focus on primary capabilities.

6.4 FUTURE WORK

Near-Term (1-3 months):

- Production deployment to enterprise environment
- Additional scanner types
- Enhanced LLM safety test suites
- Mobile application completion

- ML-powered anomaly detection

Medium-Term (3-6 months):

- Full SaaS multi-tenant deployment
- Marketplace for community integrations
- Automated compliance evidence generation
- Advanced attack simulation
- Real-time model behavior monitoring

Long-Term (6-12 months):

- Quantum-resistant encryption
- AI-powered code review for ML pipelines
- Predictive remediation
- Industry-specific compliance modules
- Agentic AI governance with autonomous remediation

6.5 LESSONS LEARNED

Technical Lessons:

1. Modular monolith architecture provides the right balance of modularity and operational simplicity.
2. Polyglot persistence pays dividends when data access patterns are clearly different.
3. FastAPI's async capabilities enable excellent performance without thread-based complexity.
4. TypeScript's type system catches entire categories of frontend bugs at compile time.
5. React Query eliminates significant boilerplate for data fetching and caching.

Professional Lessons:

1. Enterprise software requires attention to non-functional requirements from the start.
2. Documentation is a first-class deliverable in enterprise contexts.
3. Security must be integrated into every layer of the application.
4. The AI security domain is rapidly evolving, requiring adaptable architecture.
5. Open-source tools require engineering effort to integrate and operationalize.

REFERENCES

- Biggio, B., & Roli, F. (2018). Wild patterns: Ten years after the rise of adversarial machine learning. *Pattern Recognition*, 84*, 317–331.
- Carlini, N., & Wagner, D. (2017). Towards evaluating the robustness of neural networks. In *2017 IEEE Symposium on Security and Privacy (SP)** (pp. 39–57). IEEE.
- Carlini, N., Ippolito, D., Jagielski, M., Lee, K., Tramer, F., & Zhang, C. (2023). Quantifying memorization across neural language models. In *International Conference on Learning Representations (ICLR 2023)**.
- Chen, P. Y., Zhang, H., Sharma, Y., Yi, J., & Hsieh, C. J. (2017). ZOO: Zeroth-order optimization based black-box attacks to deep neural networks without training substitute models. In *Proceedings of the 10th ACM Workshop on Artificial Intelligence and Security** (pp. 15–26).
- European Parliament. (2024). *Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)**. Official Journal of the European Union.
- FastAPI. (2024). *FastAPI framework documentation.** <https://fastapi.tiangolo.com/>
- Flower Labs. (2024). *Flower: A friendly federated learning framework.** <https://flower.ai/>
- Fredrikson, M., Jha, S., & Ristenpart, T. (2015). Model inversion attacks that exploit confidence information and basic countermeasures. In *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security** (pp. 1322–1333).
- Gartner. (2025). *Market guide for AI security posture management.** Gartner Research.
- Goldblum, M., et al. (2022). Dataset security for machine learning: Data poisoning, backdoor attacks, and defenses. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 45*(2), 1563–1580.
- Goodfellow, I. J., Shlens, J., & Szegedy, C. (2015). Explaining and harnessing adversarial examples. In *International Conference on Learning Representations (ICLR 2015)**.

Gu, T., Liu, K., Dolan-Gavitt, B., & Garg, S. (2019). BadNets: Evaluating backdooring attacks on deep neural networks. *IEEE Access, 7*, 47230–47244.

IBM Research. (2024a). *Adversarial Robustness Toolbox.* <https://github.com/Trusted-AI/adversarial-robustness-toolbox>

IBM Research. (2024b). *AI Fairness 360.* <https://github.com/Trusted-AI/AIF360>

International Organization for Standardization. (2023). *ISO/IEC 42001:2023 information technology—Artificial intelligence—Management system.* ISO.

McKinsey & Company. (2025). *The state of AI in 2025: Global survey results.* McKinsey Digital.

Microsoft. (2024). *Presidio: Data protection and de-identification SDK.* <https://github.com/microsoft/presidio>

MITRE Corporation. (2023). *ATLAS: Adversarial Threat Landscape for Artificial Intelligence Systems.* <https://atlas.mitre.org/>

National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0).* NIST AI 100-1.

OpenDP. (2024). *OpenDP: The open-source differential privacy library.* <https://opendp.org/>

OWASP Foundation. (2023). *OWASP Top 10 for Large Language Model Applications.*

OWASP CycloneDX. (2024). *CycloneDX specification.* <https://cyclonedx.org/>

Perez, F., & Ribeiro, I. (2022). Ignore this title and HackAPrompt: Exposing systemic weaknesses of LLMs. In *Proceedings of the 2022 Conference on Empirical Methods in Natural Language Processing (EMNLP 2022)*.

React. (2024). *React: A JavaScript library for building user interfaces.* <https://react.dev/>

Sculley, D., et al. (2015). Hidden technical debt in machine learning systems. In *Advances in Neural Information Processing Systems* (Vol. 28, pp. 2503–2511).

Shokri, R., Stronati, M., Song, C., & Shmatikov, V. (2017). Membership inference attacks against machine learning models. In *2017 IEEE Symposium on Security and Privacy (SP)* (pp. 3–18).

SQLAlchemy. (2024). *SQLAlchemy: The Python SQL toolkit and ORM.*
<https://www.sqlalchemy.org/>

Tramer, F., Zhang, F., Juels, A., Reiter, M. K., & Ristenpart, T. (2016). Stealing machine learning models via prediction APIs. In *25th USENIX Security Symposium (USENIX Security 16)* (pp. 601–618).

Trail of Bits. (2024). *Fickling: A Python pickling decompiler.*
<https://github.com/trailofbits/fickling>

Appendices

Appendix A: Api Endpoint Reference

Authentication

Method	Endpoint	Description
POST	/api/v1/auth/login	Authenticate user, return JWT tokens
POST	/api/v1/auth/register	Create new user account
POST	/api/v1/auth/refresh	Refresh expired access token
POST	/api/v1/auth/logout	Invalidate current tokens
GET	/api/v1/auth/me	Get current user profile
PUT	/api/v1/auth/me	Update user profile
POST	/api/v1/auth/mfa/setup	Configure MFA
POST	/api/v1/auth/mfa/verify	Verify MFA code

Asset Management

Method	Endpoint	Description
GET	/api/v1/assets	List all assets (paginated)
POST	/api/v1/assets	Create new asset record
GET	/api/v1/assets/{id}	Get asset details
PUT	/api/v1/assets/{id}	Update asset record
DELETE	/api/v1/assets/{id}	Delete asset record
POST	/api/v1/assets/discover	Trigger discovery scan
GET	/api/v1/assets/statistics	Get portfolio statistics

Risk Management

Method	Endpoint	Description
GET	/api/v1/risks	List risk assessments
POST	/api/v1/risks/assess	Trigger risk assessment
GET	/api/v1/risks/{id}	Get assessment details
GET	/api/v1/risks/dashboard	Get risk dashboard
GET	/api/v1/risks/trends	Get risk trends

LLM Safety

Method	Endpoint	Description
POST	/api/v1/llm-safety/test	Run LLM safety test
GET	/api/v1/llm-safety/results	Get test results
POST	/api/v1/llm-safety/red-team	Start red team session
GET	/api/v1/llm-safety/sessions	List red team sessions

AI-BOM

Method	Endpoint	Description
POST	/api/v1/ai-bom/generate	Generate AI-BOM
GET	/api/v1/ai-bom/{id}	Get AI-BOM by ID
GET	/api/v1/ai-bom/list	List all AI-BOMs
POST	/api/v1/ai-bom/{id}/export	Export BOM
POST	/api/v1/ai-bom/compare	Compare two BOMs

Appendix B: Database Schema

TABLE: ai_assets

Column	Type / Constraints
id	UUID PRIMARY KEY
name	VARCHAR(255) NOT NULL
asset_type	VARCHAR(50) NOT NULL
status	VARCHAR(50) DEFAULT 'ACTIVE'
risk_tier	VARCHAR(20) DEFAULT 'MEDIUM'
risk_score	FLOAT DEFAULT 0.0
framework	VARCHAR(100)
owner	VARCHAR(255)
department	VARCHAR(255)
deployment_environment	VARCHAR(50)
cloud_provider	VARCHAR(50)
data_classification	VARCHAR(50)
vulnerability_count	INTEGER DEFAULT 0
compliance_frameworks	JSONB
created_at	TIMESTAMP DEFAULT NOW()
updated_at	TIMESTAMP DEFAULT NOW()

TABLE: users

Column	Type / Constraints
id	UUID PRIMARY KEY
email	VARCHAR(255) UNIQUE NOT NULL
username	VARCHAR(100) UNIQUE NOT NULL
password_hash	VARCHAR(255) NOT NULL
role	VARCHAR(50) NOT NULL
permissions	JSONB
mfa_enabled	BOOLEAN DEFAULT FALSE
is_active	BOOLEAN DEFAULT TRUE
created_at	TIMESTAMP DEFAULT NOW()

TABLE: vulnerabilities

Column	Type / Constraints
id	UUID PRIMARY KEY
asset_id	UUID REFERENCES ai_assets(id)
title	VARCHAR(500) NOT NULL
severity	VARCHAR(20) NOT NULL
category	VARCHAR(100)
atlas_technique	VARCHAR(50)
owasp_category	VARCHAR(50)
status	VARCHAR(50) DEFAULT 'OPEN'
discovered_at	TIMESTAMP DEFAULT NOW()

Appendix C: Configuration Parameters

Core Application

Parameter	Value / Default
APP_NAME	AI-SPM Platform
APP_VERSION	1.0.0
ENVIRONMENT	production staging development
API_V1_PREFIX	/api/v1

Database

Parameter	Value / Default
DATABASE_URL	postgresql+asyncpg://user:pass@host:5432/ai_spm
DB_POOL_SIZE	10
DB_MAX_OVERFLOW	20

Authentication

Parameter	Value / Default
SECRET_KEY	<min-32-chars>
ACCESS_TOKEN_EXPIRE_MINUTES	60
REFRESH_TOKEN_EXPIRE_DAYS	7
ALGORITHM	HS256

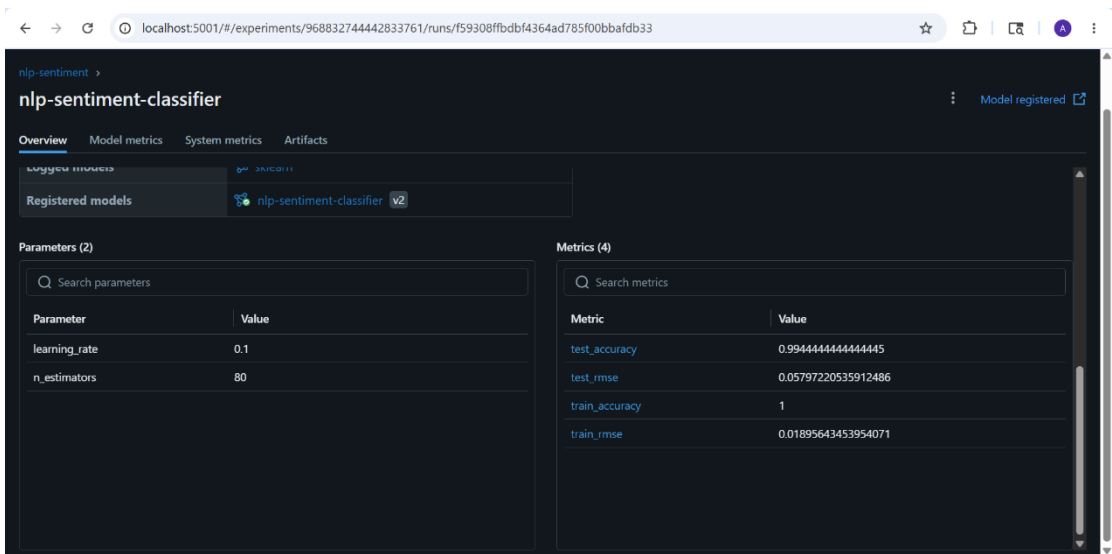
Security

Parameter	Value / Default
CORS_ORIGINS	["https://app.domain.com"]
RATE_LIMIT_PER_MINUTE	100
MAX_UPLOAD_SIZE_MB	100

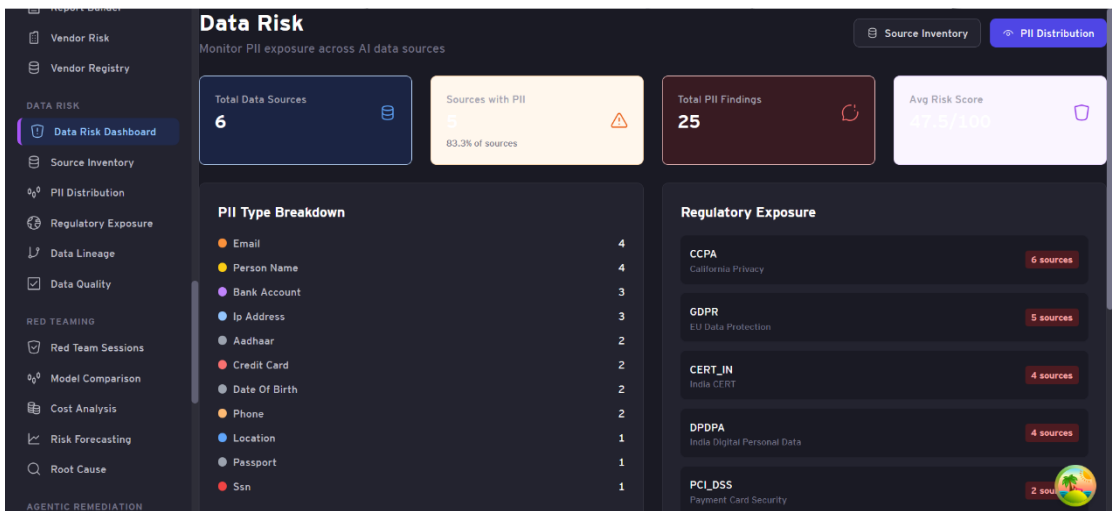
Compliance

Parameter	Value / Default
EU_AI_ACT_ENABLED	true
NIST_AI_RMF_ENABLED	true
ISO_42001_ENABLED	true
OWASP_LLM_ENABLED	true
MITRE_ATLAS_ENABLED	true

Appendix D: Screenshots of Application



ML model monitoring interface displaying registered model details, hyperparameters, and performance metrics including accuracy and error rates for evaluation and validation.



A dark-themed “Data Risk Dashboard” interface displaying key metrics such as total data sources (6), sources with PII (5, 83.3%), total PII findings (25), and average risk score, along with detailed breakdowns of PII types (like email, names, bank accounts) and regulatory exposure across frameworks such as CCPA, GDPR, and PCI DSS.